

COURSE: “CYBER FORENSICS AND ETHICAL HACKING”

TOPIC 1

WINDOWS OS SECURITY

Lesson 2 · Windows OS Services | Seminar, 2 hours



REPUBLIC OF UZBEKISTAN
UNIVERSITY OF MILITARY SECURITY AND
DEFENSE
Institute of ICT and Military Communications ·
Cybersecurity Department

Lecturer: Senior Lecturer, Cybersecurity Department — Captain M. Isakov

Lesson 2: Windows OS Services (Seminar)



Topic

Windows OS security



Session type

Seminar



Duration

2 hours

Learning questions

1

User Account Control, AppLocker and SmartScreen security systems

2

Defender and Firewall security systems



Link to Lesson 1

- ▶ **AppLocker** works only if the **Application Identity** service is running.
- ▶ **Defender** and **Firewall** are themselves services (WinDefend, MpsSvc).
- ▶ Today: the tools that stop an attack before and after it starts.

QUESTION 1

UAC, AppLocker and SmartScreen security systems

UAC — why it was introduced and what it does



The problem (Windows XP)

- ▶ Users worked with administrator rights all the time.
- ▶ Any malware they launched got full admin rights instantly.



The solution (since Windows Vista)

- ▶ Even an admin works with reduced (standard) rights.
- ▶ Admin rights are used only after an explicit “Yes”.

What UAC asks for — depends on who you are:



Administrator → Consent prompt

Just click “Yes” or “No”.



Standard user → Credential prompt

An administrator’s user name and password must be entered.



Secure Desktop

The screen dims — malware cannot click a fake “Yes” button.

Where to open: Start → type “User Account Control” → **Change User Account Control settings**

How UAC works — step by step

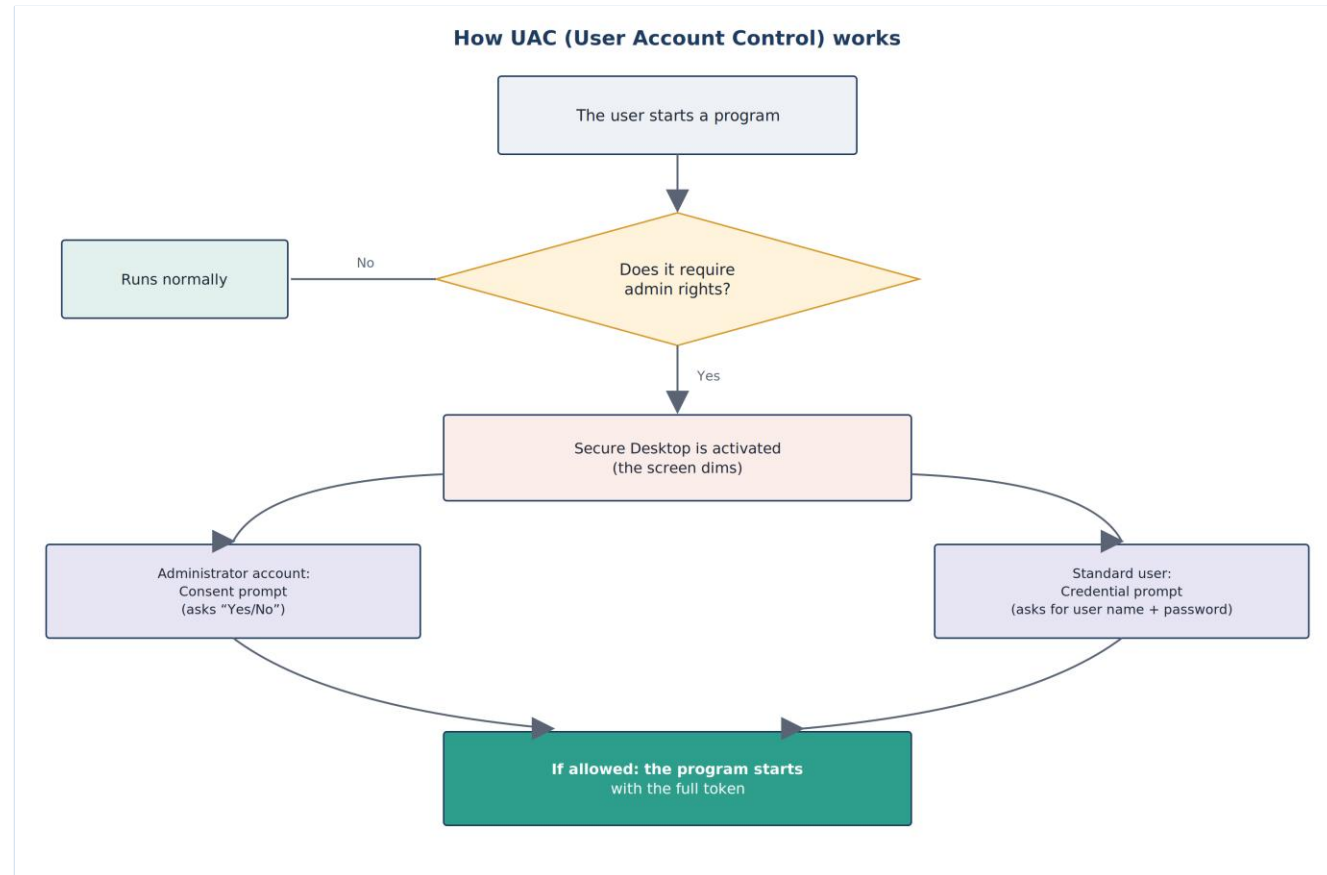


Fig. 1. How UAC (User Account Control) works

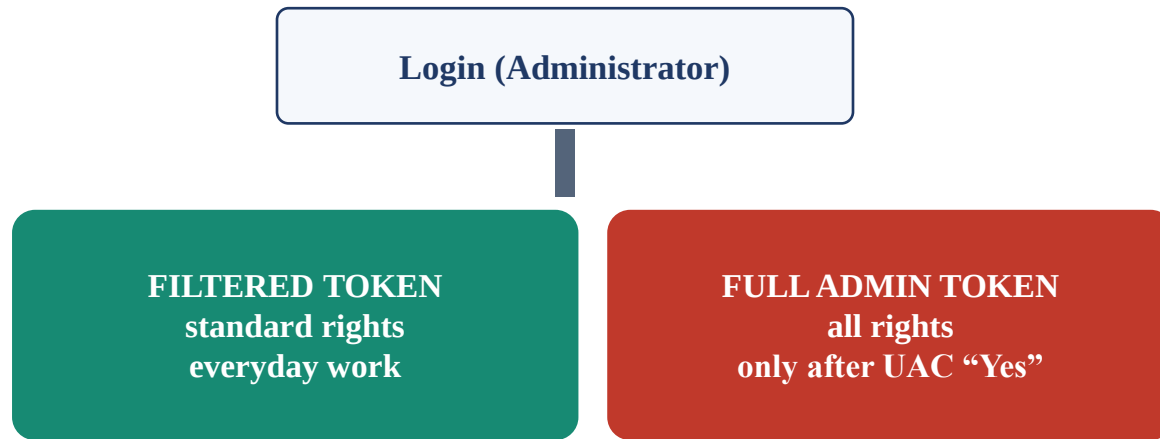
- 1 **A program starts** — with the ordinary (filtered) token.
- 2 **Needs admin rights?** — No → runs normally. Yes → go on.
- 3 **Secure Desktop** — the screen dims, only the prompt is active.
- 4 **Prompt** — Admin: Yes/No. Standard user: password.
- 5 **Allowed** — the program runs with the full token.

Terms (click for explanation):

? Secure Desktop

? Access token

Two tokens and integrity levels — what UAC is built on



Admin Approval Mode: an administrator receives two tokens at sign-in. Everyday programs get the filtered one; the full one is activated only for the confirmed program. This is **least privilege** in practice.

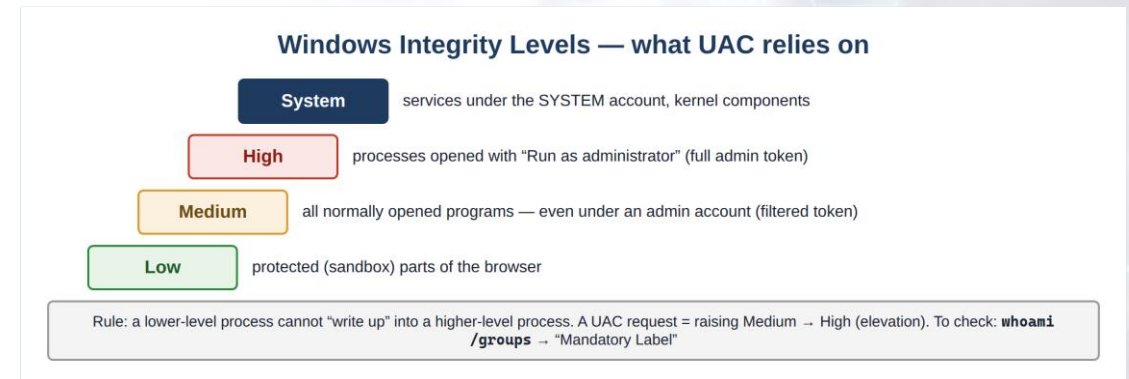


Fig. 2. Windows Integrity Levels

> `whoami /groups` → Mandatory Label\Medium / High

Terms:

? Integrity level

? Access token

QUESTION 1 • USER ACCOUNT CONTROL

What the UAC prompt looks like — learn to read it

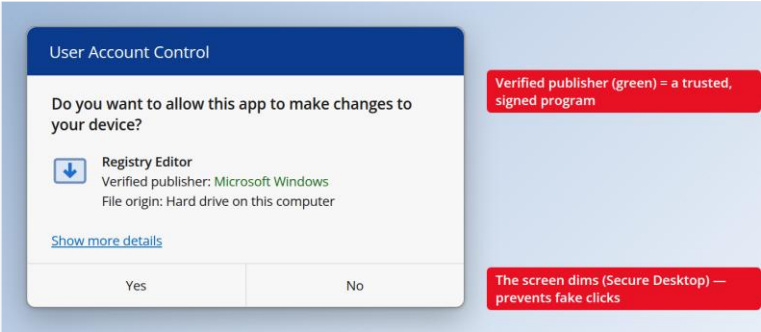


Fig. 3. Signed program — Verified publisher (green)

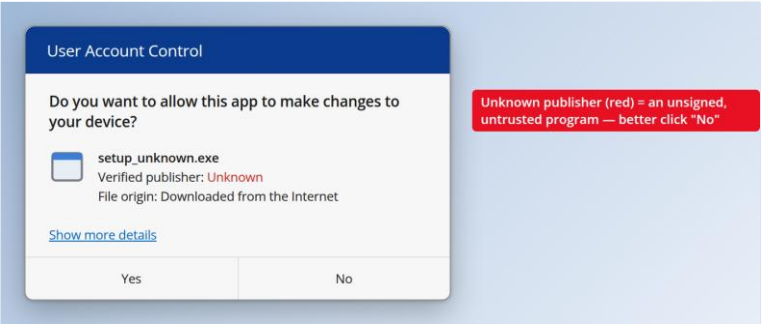


Fig. 4. Unsigned program — Unknown publisher (red)

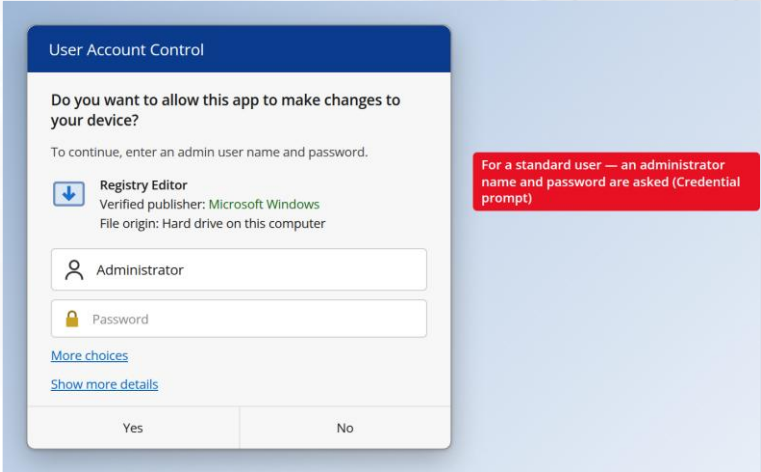


Fig. 5. Standard user — Credential prompt

Trusted: Microsoft Windows

Warning sign → click “No”

Admin name + password needed

Three lines to read before clicking “Yes”:

Program name

is it the program you started yourself?

Verified publisher

green name = signed; red “Unknown” = unsigned

File origin

“Downloaded from the Internet” needs extra care

UAC levels — the slider and what it changes

Always notify

Warns on every change, even Windows settings. Uses Secure Desktop.

Military /
government networks

Notify when apps change (default)

Warns only for programs. Uses Secure Desktop.

Most users

Notify — do not dim

Same, but without Secure Desktop — weaker.

Not recommended

Never notify

UAC is effectively off — very dangerous.

Never use

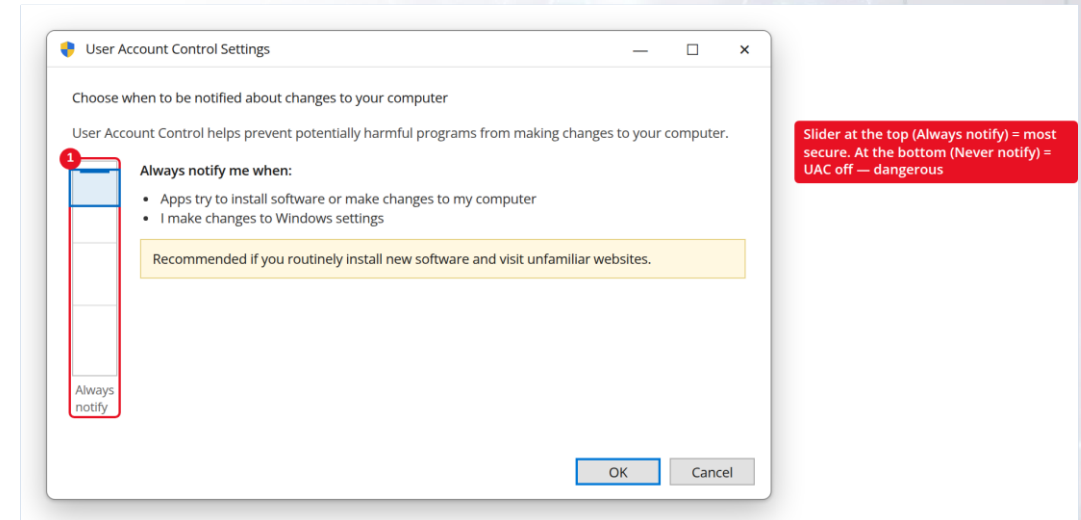


Fig. 6. UAC settings window — slider at “Always notify”

Registry: HKLM\...\Policies\System

EnableLUA = 1 → UAC on

ConsentPromptBehaviorAdmin = 2 always · 5 default · 0 never

PromptOnSecureDesktop = 1 dim · 0 no dim

AppLocker — “only allowed programs may run”



UAC controls **who may do what**; AppLocker controls **which programs may run at all**. The administrator lists what is allowed (**whitelist**) — everything else is blocked, even if the user says “Yes”.

5 rule collections — by file type:

Executable

.exe .com

Windows Installer

.msi .msp

Script

.ps1 .vbs .js .bat

Packaged app

UWP apps

DLL

.dll .ocx

Each rule uses one of 3 conditions:



Publisher — by digital signature
Most flexible — survives updates



Path — by file location
e.g. only C:\Program Files



File hash — by the file’s fingerprint
Strictest — breaks on every update

? Whitelist

? File hash

How AppLocker decides: run or block?

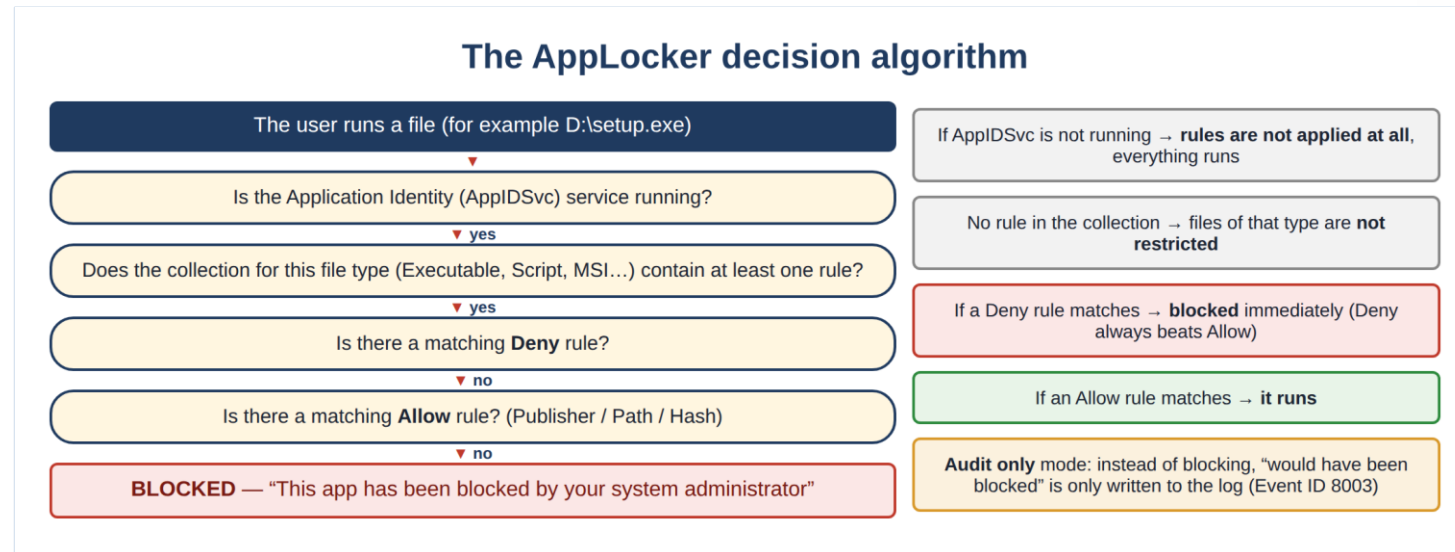


Fig. 7. The AppLocker decision algorithm



Important

- ▶ **Application Identity** (AppIDSvc) must be running.
- ▶ Full support: Enterprise / Education / Server only.

Two modes:

- ▶ **Enforce rules** — really blocks.
- ▶ **Audit only** — only logs “would be blocked” (Event ID 8003). Use it to test rules first.

QUESTION 1 · APPLOCKER

Where AppLocker lives and what the user sees

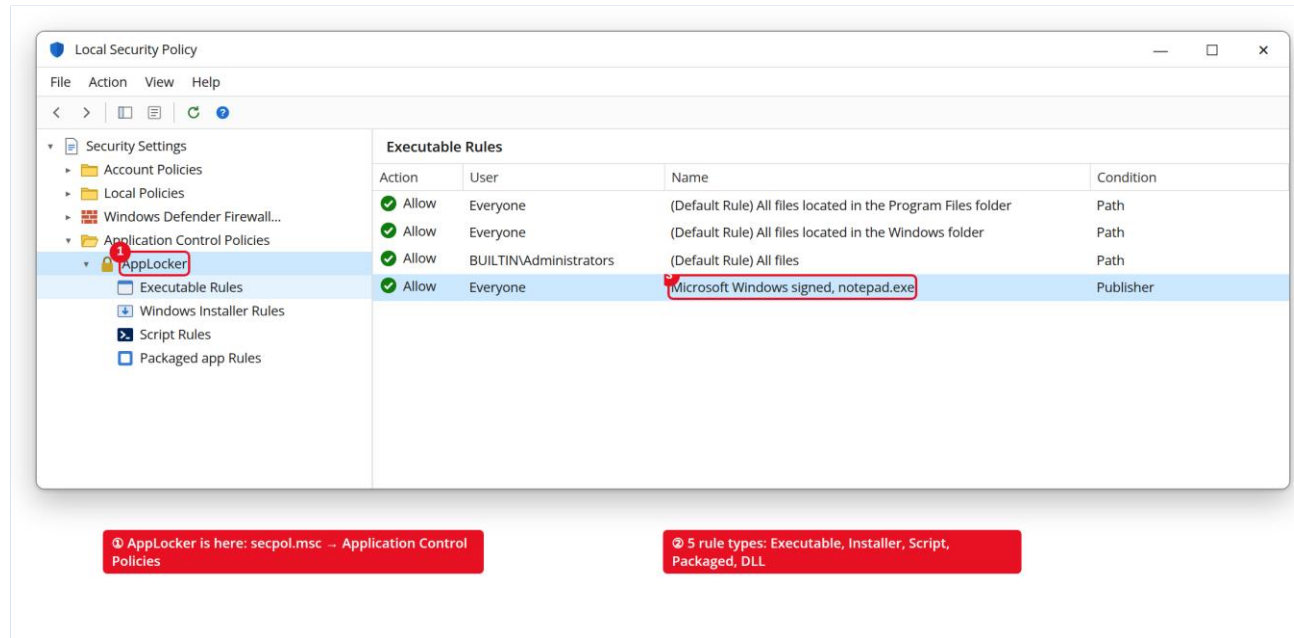


Fig. 8. secpol.msc → Application Control Policies → AppLocker

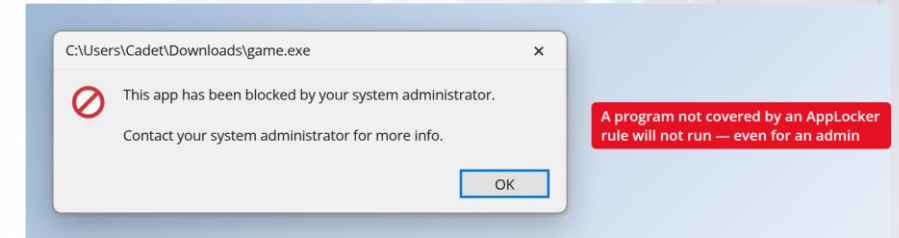


Fig. 9. A program blocked by AppLocker

Open: Win + R → secpol.msc
→ Application Control Policies → AppLocker
(or gpedit.msc → Computer Configuration → ...)



Practical example: a Path rule allows programs only from **C:\Windows** and **C:\Program Files**. Any **.exe** from Downloads or a USB flash drive is blocked automatically — even for an administrator.

SmartScreen — checking reputation before a file runs

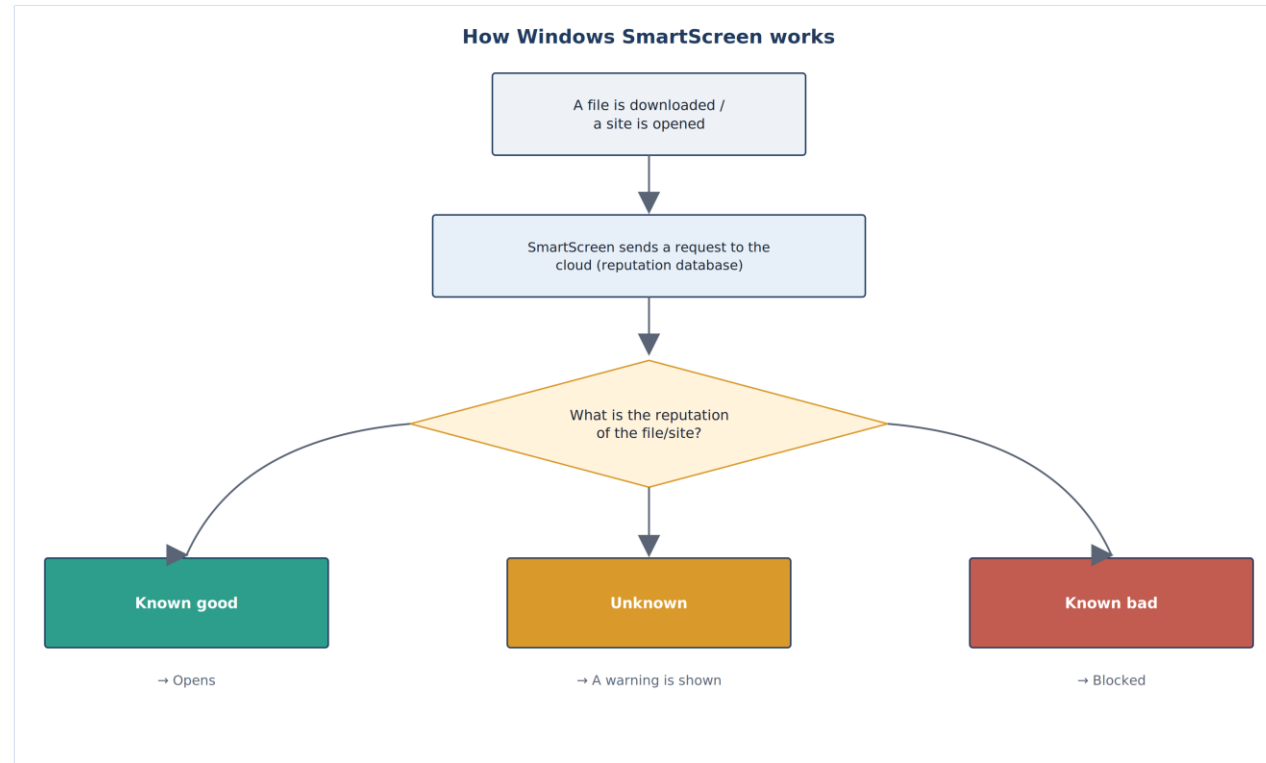


Fig. 10. How Windows SmartScreen works



Cloud reputation

- ▶ Microsoft keeps the “reputation” of millions of files and sites.
- ▶ New or rarely downloaded files are treated as risky.

Why it is effective

- ▶ Catches phishing sites and brand-new malware —
- ▶ even when no antivirus signature exists yet.

AppLocker controls programs on the system; **SmartScreen** checks what comes **from the internet**.

The SmartScreen warning and the Mark of the Web

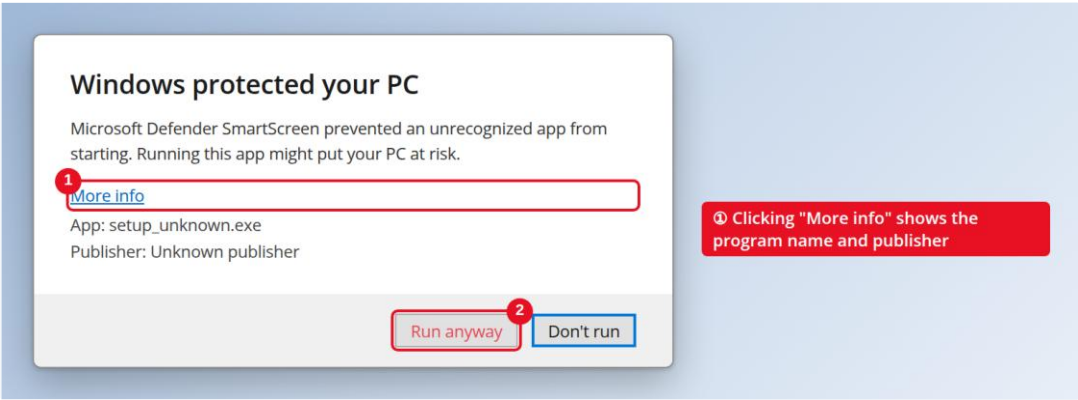


Fig. 11. “Windows protected your PC” — More info / Run anyway

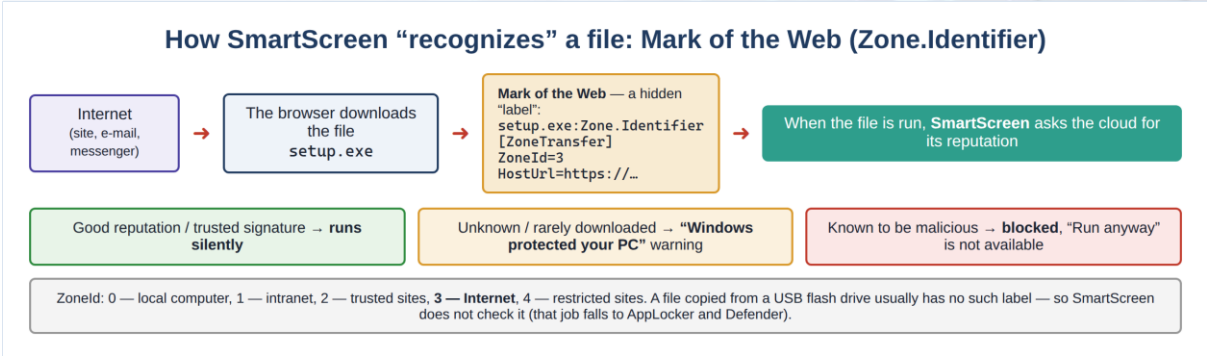


Fig. 12. Mark of the Web (Zone.Identifier)



“More info” — shows the file name and publisher.



“Run anyway” — continue at your own risk — makes the user stop and think.



ZoneId = 3 — the file came from the Internet → SmartScreen checks it.

Settings: Windows Security → App & browser control → Reputation-based protection

? Mark of the Web

UAC vs AppLocker vs SmartScreen — who stops what?

	UAC	AppLocker	SmartScreen
Question it asks	May this program get admin rights?	May this program run at all?	Is this file/site trusted?
When it acts	When admin rights are requested	Every time a file starts	When a downloaded file runs / a site opens
Can the user override?	Yes — click “Yes” (or give a password)	No — only the administrator	Yes — “More info → Run anyway”
Where to configure	Control Panel → User Accounts	secpol.msc / gpedit.msc	Windows Security → App & browser
Editions	All	Enterprise / Education / Server	All

Seminar task: a user downloaded **game.exe** from a website. Which of the three tools reacts first, second, third — and why?

QUESTION 2

Defender and Firewall security systems

Windows Defender — the built-in antivirus

UAC, AppLocker and SmartScreen **block in advance**. Defender **scans** files that already exist or are running, and detects malicious behaviour.



Real-time protection — checks each file as it is opened, downloaded or run



Cloud-delivered protection — recognizes new threats using the cloud database



Automatic sample submission — sends suspicious unknown files to Microsoft



Tamper Protection — malware cannot switch Defender off



Controlled folder access — protects Documents/Pictures from ransomware

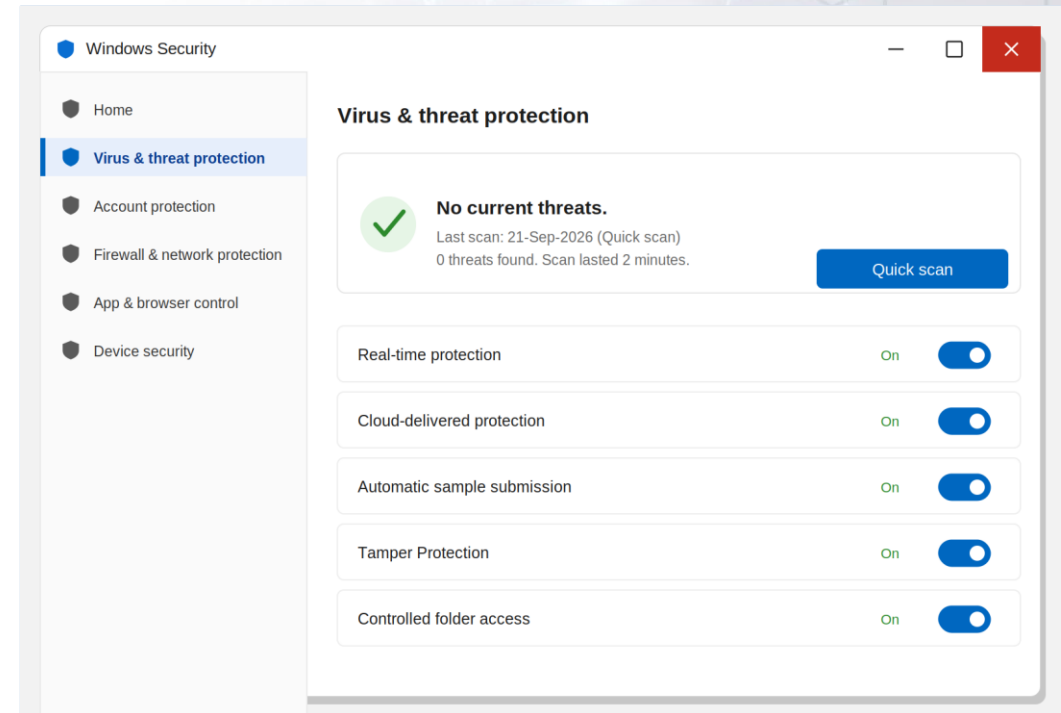


Fig. 13. Windows Security → Virus & threat protection

```
PS> Get-MpComputerStatus
RealTimeProtectionEnabled : True
```

Windows Firewall — directions and network profiles



Inbound

traffic coming INTO the computer — blocked by default unless a rule allows it



Outbound

traffic LEAVING the computer — allowed by default unless a rule blocks it

Each rule: port, program or protocol → Allow or Block. Three profiles — three rule sets:



Domain

Computer is joined to a corporate domain (Active Directory)

Medium — the internal network is trusted more



Private

Home or trusted private network

Medium — e.g. file sharing allowed



Public

Café, airport, hotel — unknown networks

Strictest — most incoming connections blocked

? Firewall profile

Where the Firewall is configured

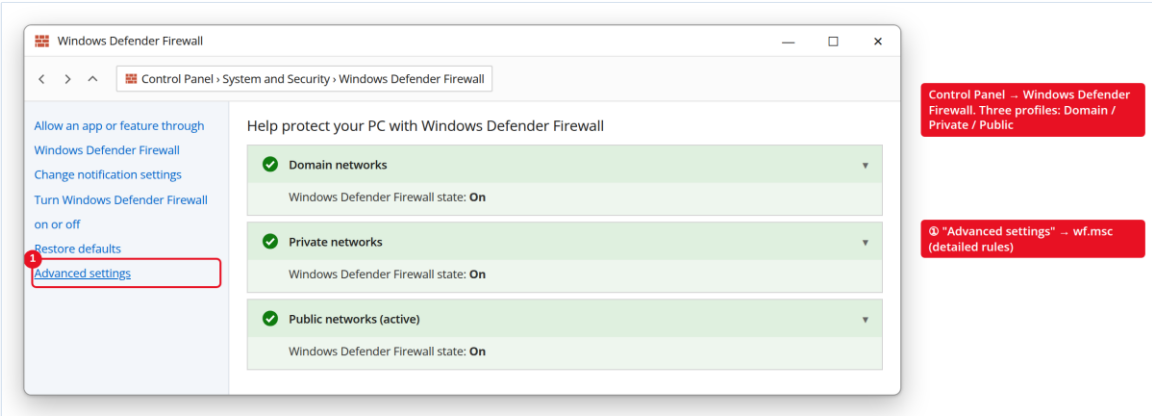


Fig. 14. Control Panel → Windows Defender Firewall — three profiles

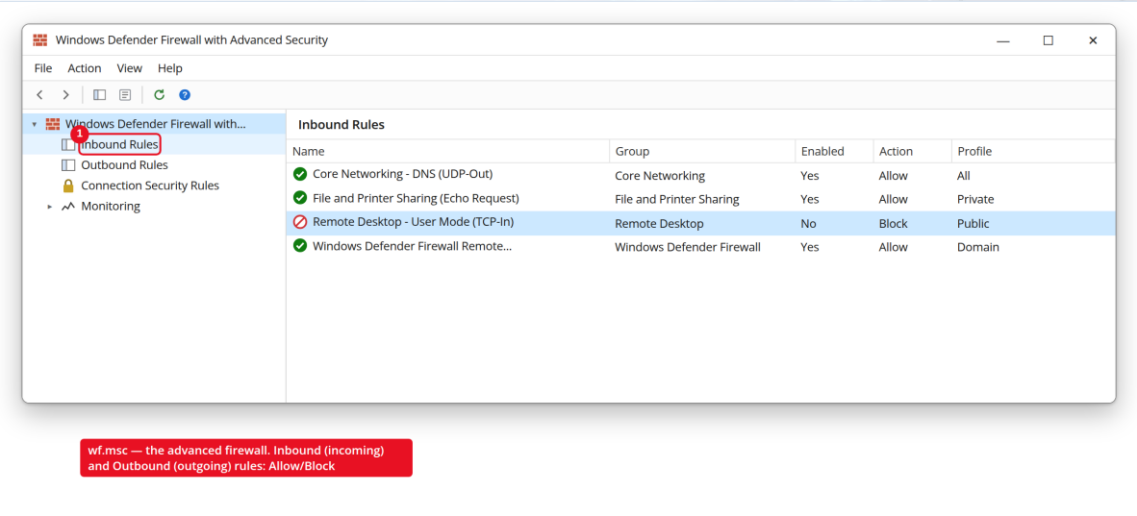


Fig. 15. wf.msc — Inbound rules (Allow / Block)

Quick view	Windows Security → Firewall & network protection	Classic	Win + R → control → Windows Defender Firewall
Advanced rules	Win + R → wf.msc (or “Advanced settings”)	PowerShell	Get-NetFirewallProfile Select Name, Enabled

How the Firewall decides about an incoming packet

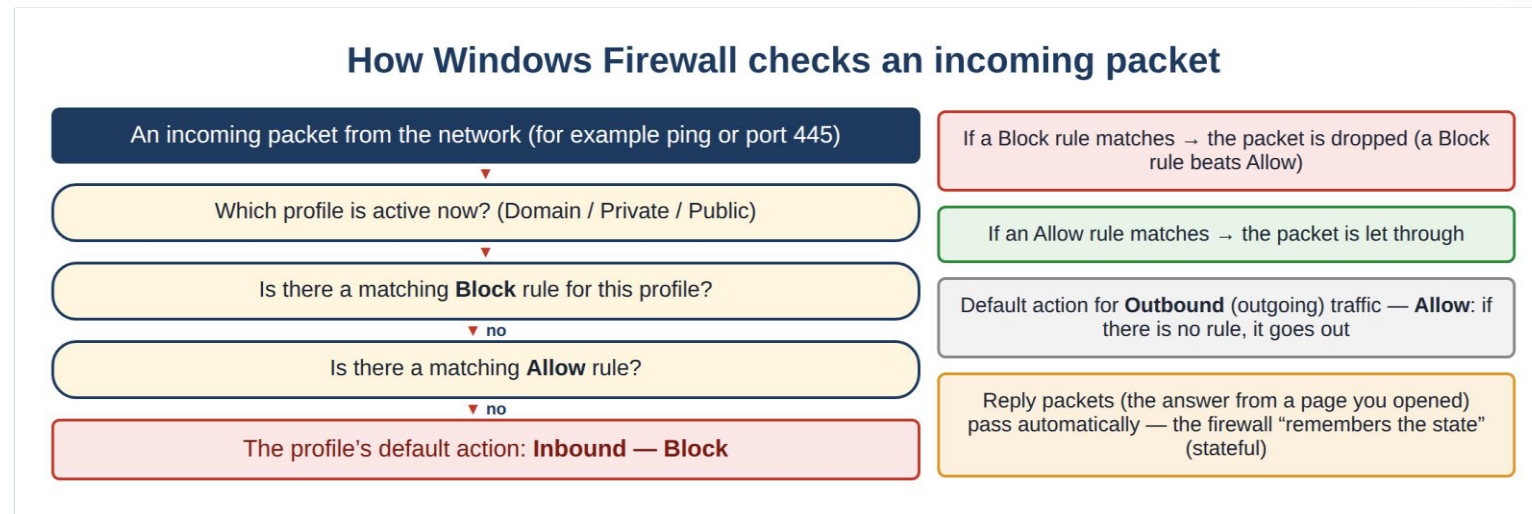


Fig. 16. Windows Firewall — checking an incoming packet



Block beats Allow

if both rules match, the packet is dropped



Stateful

replies to your own requests pass automatically



Public = strictest

unknown networks get the tightest rules

All tools together — defense in depth

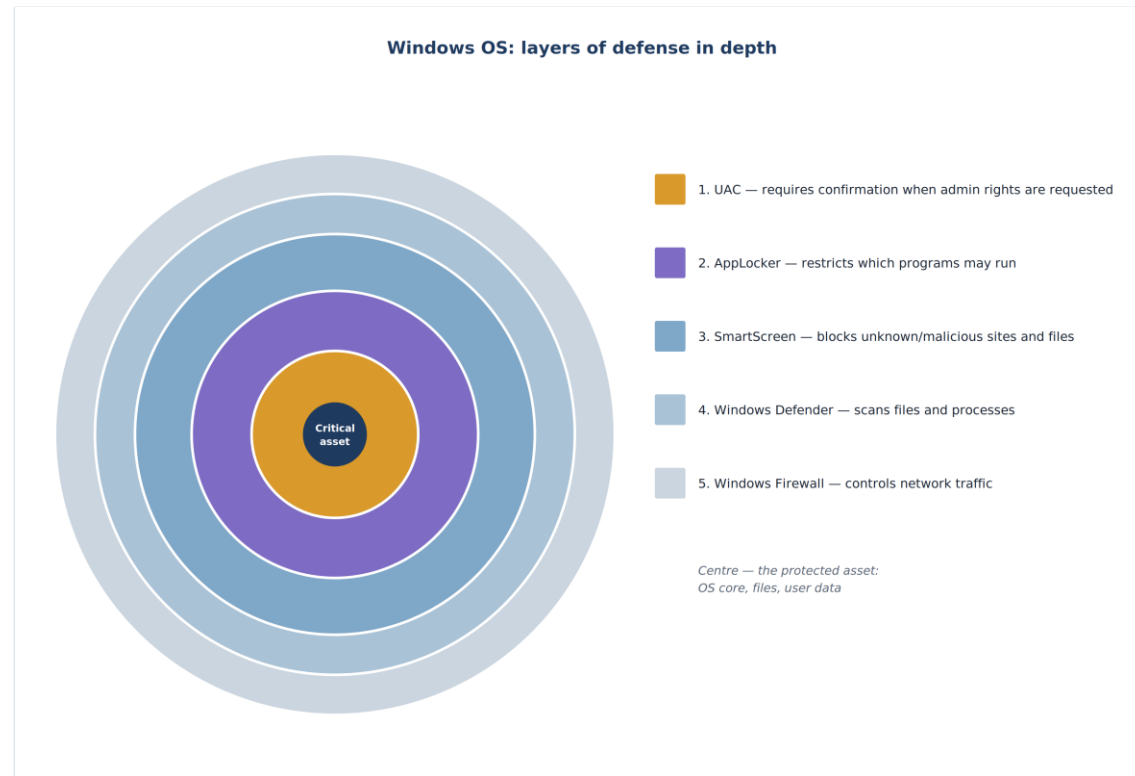


Fig. 17. Windows OS: layers of defense in depth

? Defense in depth

What each layer mainly protects against:

UAC

admin rights used without the user knowing

AppLocker

unauthorized / unknown programs running

SmartScreen

malicious downloads and phishing sites

Defender

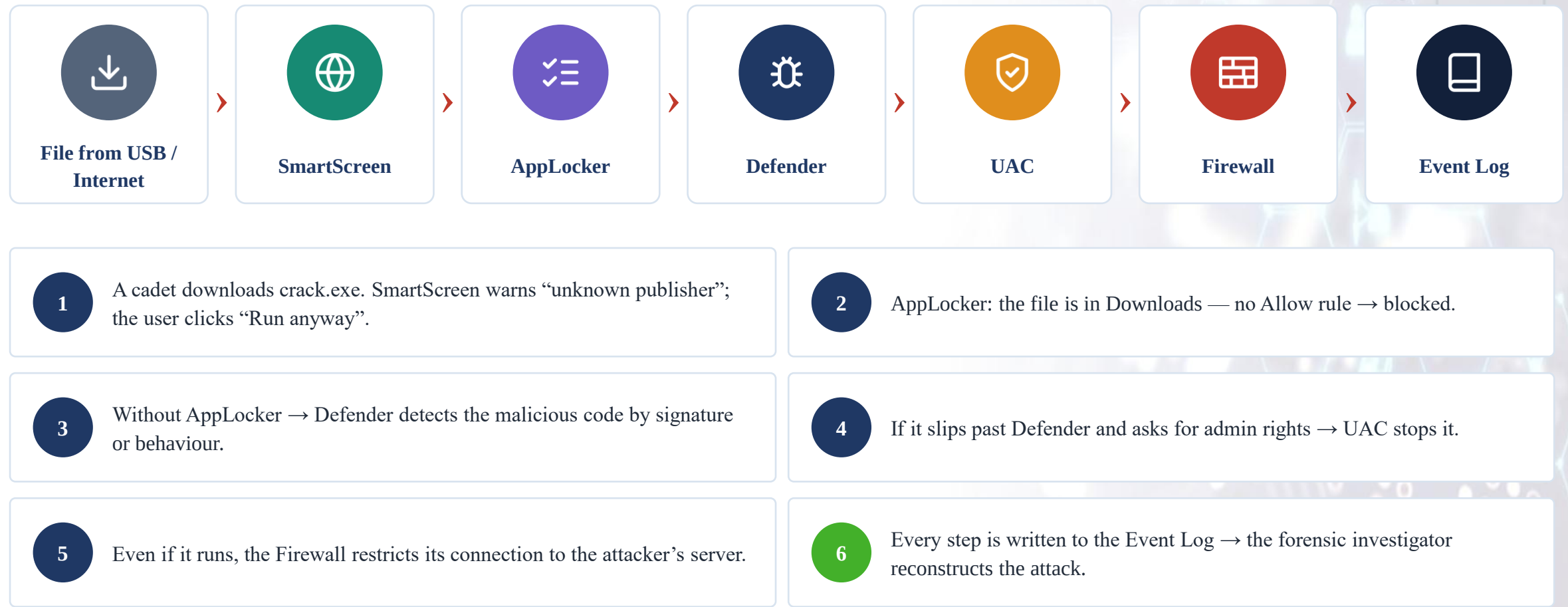
malicious code already on the computer

Firewall

unauthorized network connections

Idea: if an attacker gets past one layer, the next one stops them.

One attack — several layers of protection



Summary



UAC — admin rights only after an explicit confirmation; even an administrator works with a filtered token.



AppLocker — only allowed programs may run (Publisher / Path / File hash); needs the AppIDSvc service.



SmartScreen — checks the reputation of files and sites from the internet (Mark of the Web).



Defender — scans existing and running files; Tamper Protection and Controlled folder access protect it and your data.



Firewall — Inbound/Outbound rules in Domain, Private and Public profiles; together all five form defense in depth.

Review questions — Lesson 2

1 Why was UAC introduced and what problem does it solve?

2 What is the difference between the Consent prompt and the Credential prompt?

3 Why are the filtered token and the full admin token needed?

4 Explain AppLocker's three rule conditions (Publisher, Path, File Hash).

5 Against which types of threats is SmartScreen especially effective?

6 What does Defender's Controlled folder access protect against?

7 Explain the difference between the Domain, Private and Public profiles.

8 What does the "defense in depth" principle mean?



THANK YOU FOR YOUR ATTENTION!

Questions are welcome.

Next section — glossary of terms

GLOSSARY

Glossary — this section explains the following



Integrity level

Low / Medium / High / System



Secure Desktop

the dimmed, protected screen



Access token

a program's "ID card"



Whitelist

the "allowed" list



File hash

a file's fingerprint



Mark of the Web

the "from the Internet" label



Firewall profile

Domain / Private / Public



Defense in depth

several layers of protection

Each term is explained in beginner-friendly language, with an example and a diagram.

Integrity level (trust level of a process)

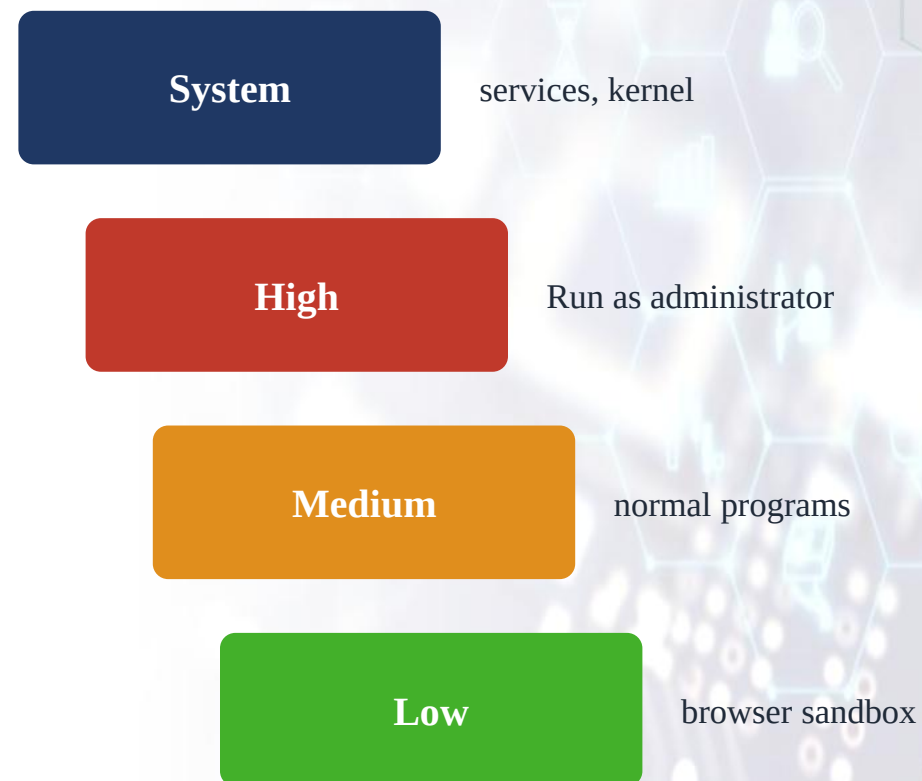
In plain terms:

Every running program gets a trust label: **Low**, **Medium**, **High** or **System**. A program with a lower level cannot change a program with a higher level.

Why it matters:

UAC is exactly the jump from **Medium** to **High**. Your browser runs at Medium (its sandbox even at Low), so a hacked web page cannot touch system files.

Check it: `whoami /groups` → “Mandatory Label”.



▲ *higher = more trusted*

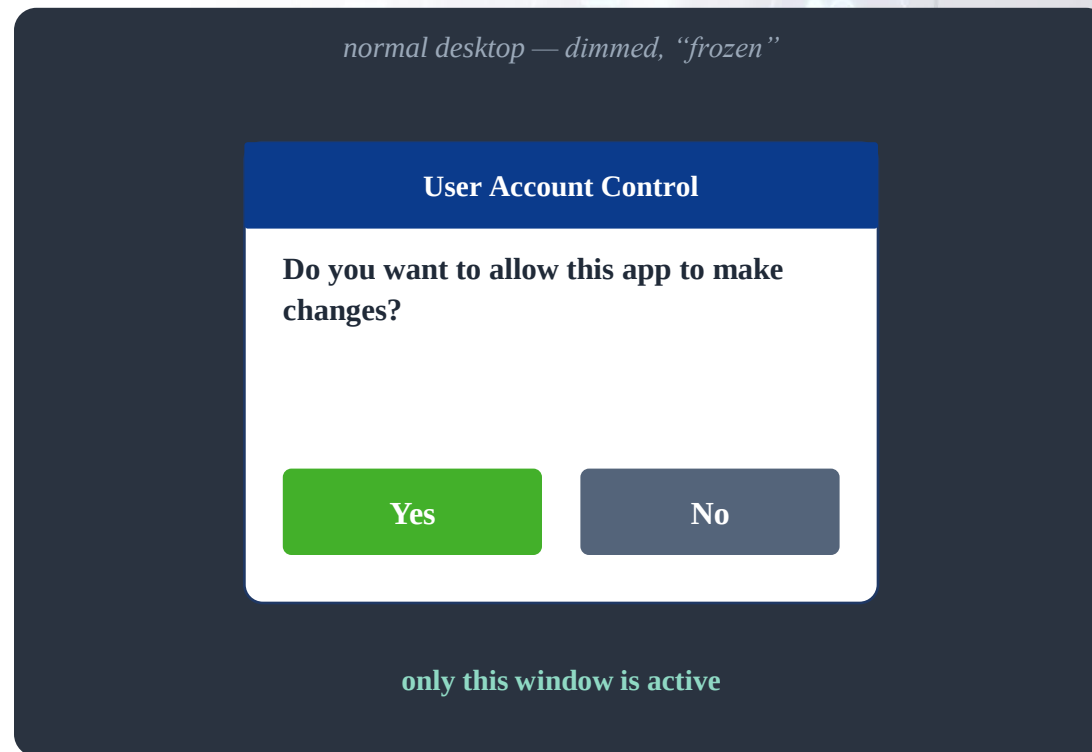
Secure Desktop

In plain terms:

When UAC asks “Do you want to allow...?”, Windows switches to a separate, protected desktop: the screen behind it dims and **only the prompt can be clicked**. Ordinary programs cannot see or control it.

Why it matters:

Without it, malware could draw a fake window or “click” the **Yes** button by itself. On the Secure Desktop, only a real person with the mouse/keyboard can answer.



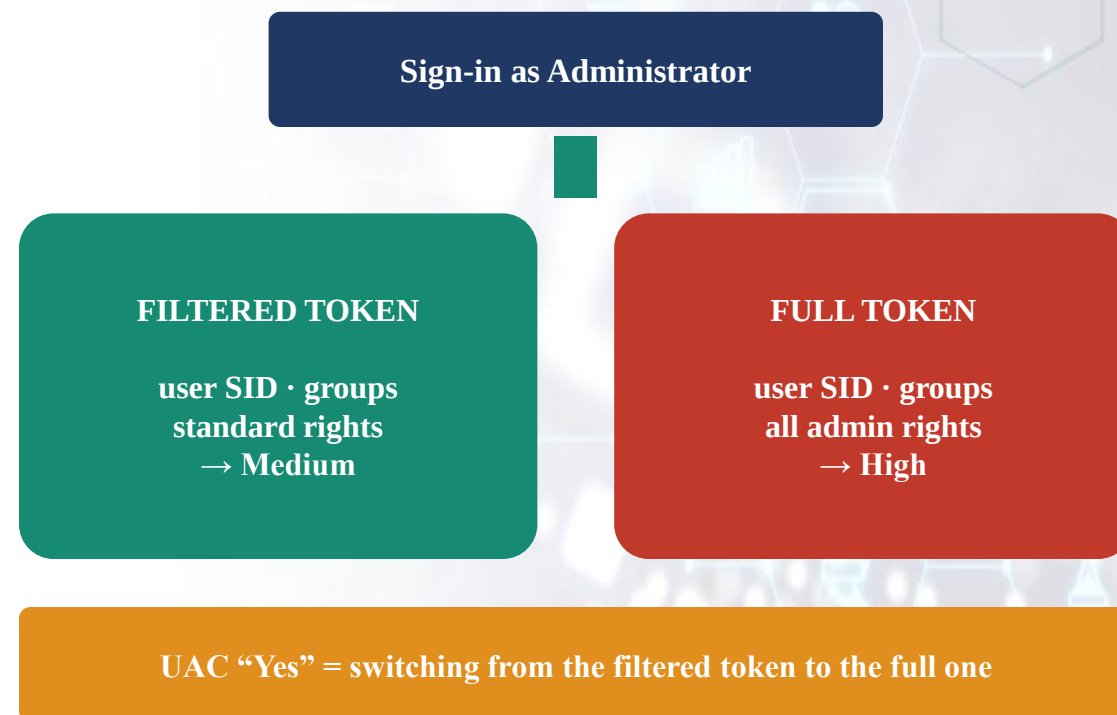
Access token (filtered and full)

In plain terms:

An access token is a program's **"ID card"**: it lists who you are (your SID), your groups and your privileges. Windows checks this card every time the program opens a file or changes a setting.

Why it matters:

An administrator gets **two cards** at sign-in: a **filtered** one for everyday work and a **full** one that is used only after the UAC "Yes". This is how UAC protects even admins.



Whitelist (allow list)

In plain terms:

A whitelist is a list of what is **allowed**. Anything not on the list is **forbidden by default**. The opposite is a blacklist: everything is allowed except what is listed.

Why it matters:

New malware is never on any blacklist yet — but it is also not on the whitelist, so it is blocked. That is why AppLocker (a whitelist) is so strong in military and corporate networks.



notepad.exe (Microsoft, signed)



C:\Program Files*



game.exe (Downloads)



crack.exe (USB drive)

green = on the list · red = not on the list → blocked

File hash (a file's fingerprint)

In plain terms:

A hash function turns a whole file into a short, fixed-length code (for example **SHA-256**). The same file always gives the same hash; change even **one byte** and the hash becomes completely different.

Why it matters:

An AppLocker **File hash** rule allows exactly one version of one file. It is the strictest condition — but after every update the hash changes and the rule must be rewritten.

setup.exe v1.0



3F9A...C21B

setup.exe v1.1



A04D...77E9

One small change → a new hash → the old AppLocker rule no longer matches. **Check a hash:** `Get-FileHash setup.exe`

Mark of the Web (Zone.Identifier)

In plain terms:

When a browser saves a file from the internet, Windows quietly attaches a hidden label to it — the **Zone.Identifier** stream. It says where the file came from (**ZoneId=3** means “Internet”).

Why it matters:

SmartScreen and Office look at this label: a file “from the Internet” is checked and may open in protected mode. A file copied from a USB drive usually has no label — so SmartScreen does not check it.

```
PS> Get-Content .\setup.exe -Stream Zone.Identifier  
[ZoneTransfer]  
ZoneId=3  
HostUrl=https://example.com/setup.exe
```

0

this computer

1

intranet

2

trusted sites

3

Internet

4

restricted sites

Firewall profile (Domain / Private / Public)

In plain terms:

A profile is a **set of firewall rules** tied to the type of network. Windows picks the profile automatically when you connect: domain network → Domain; you said “private” → Private; otherwise → Public.

Why it matters:

The same laptop needs different protection at the office and in a café. On Public, almost all incoming connections are blocked, so strangers on the same Wi-Fi cannot reach your shared folders.

Check: `Get-NetConnectionProfile`



Domain

office, Active Directory



Private

home, trusted



Public

café, airport — strictest

Defense in depth

In plain terms:

Instead of trusting one strong wall, you build **several independent layers**. Each layer can fail — but an attacker must defeat all of them to succeed.

Why it matters:

No single tool is perfect: users click “Run anyway”, new malware has no signature yet. With five layers (SmartScreen, AppLocker, Defender, UAC, Firewall) one mistake does not mean a compromised system.

